

A Comprehensive Study of Signal Handshake Protocols:

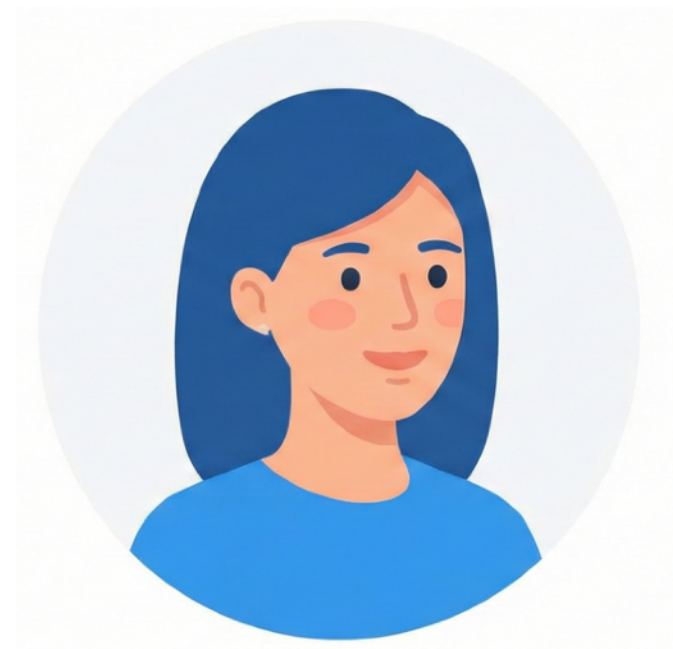
X3DH, PQXDH to Fully Post-Quantum with Deniable Ring Signatures

Keitaro Hashimoto, Shuichi Katsumata, **Guilhem Niot**,
Ida Tucker, Thom Wiggers

Security Seminar @ Berkeley – 03/12/2025



Secure Messaging

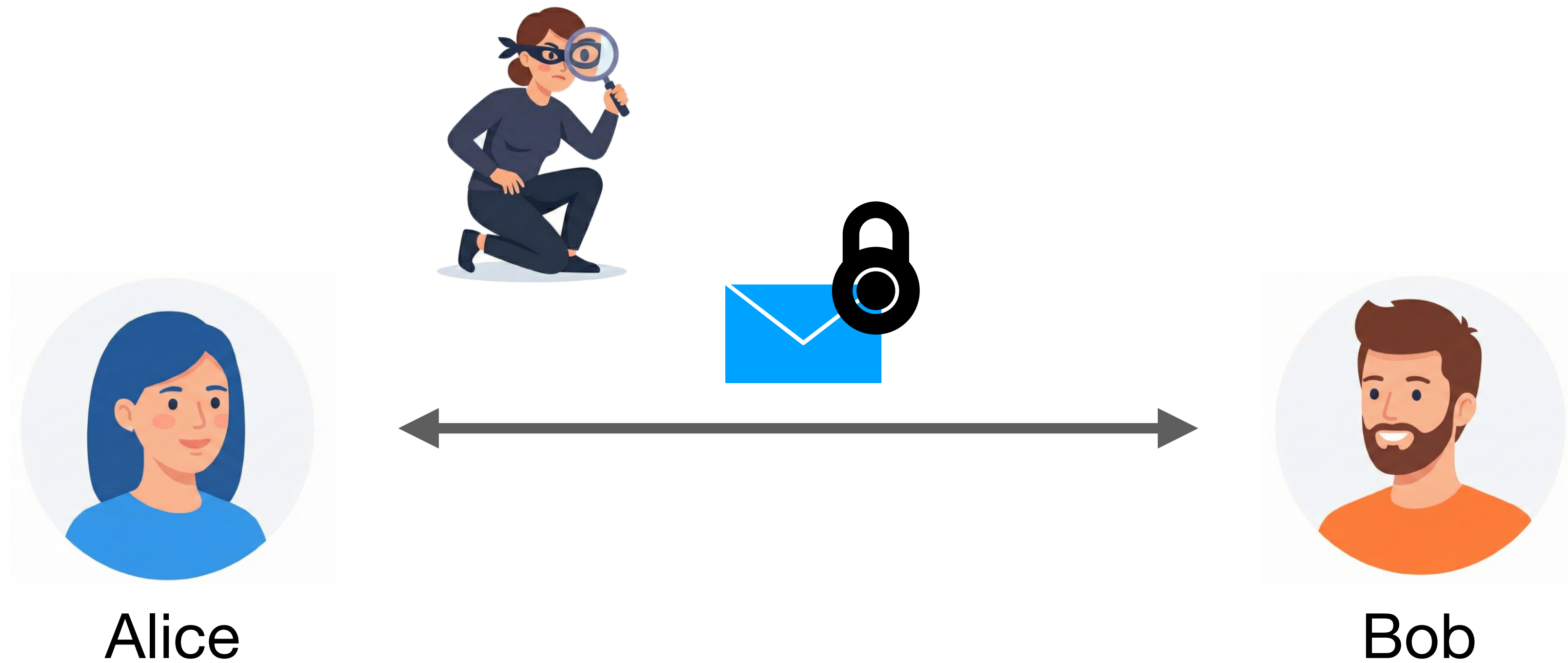


Alice

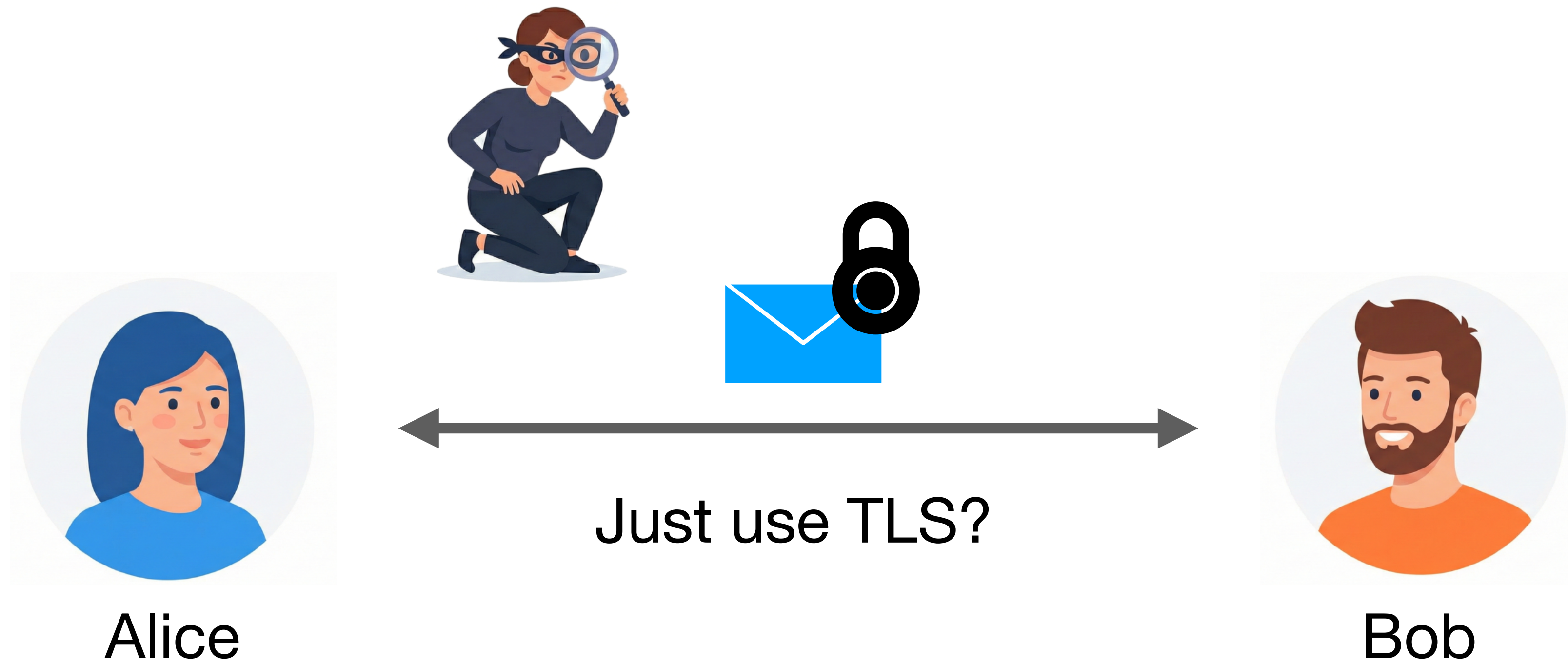


Bob

Secure Messaging



Secure Messaging



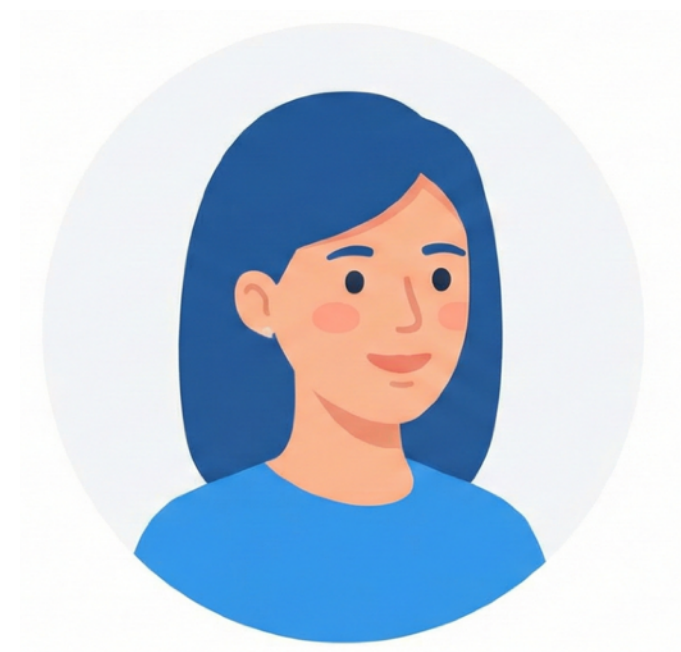
Secure Messaging

Issue: Users are not always online.



Secure Messaging

Issue: Users are not always online.



Alice



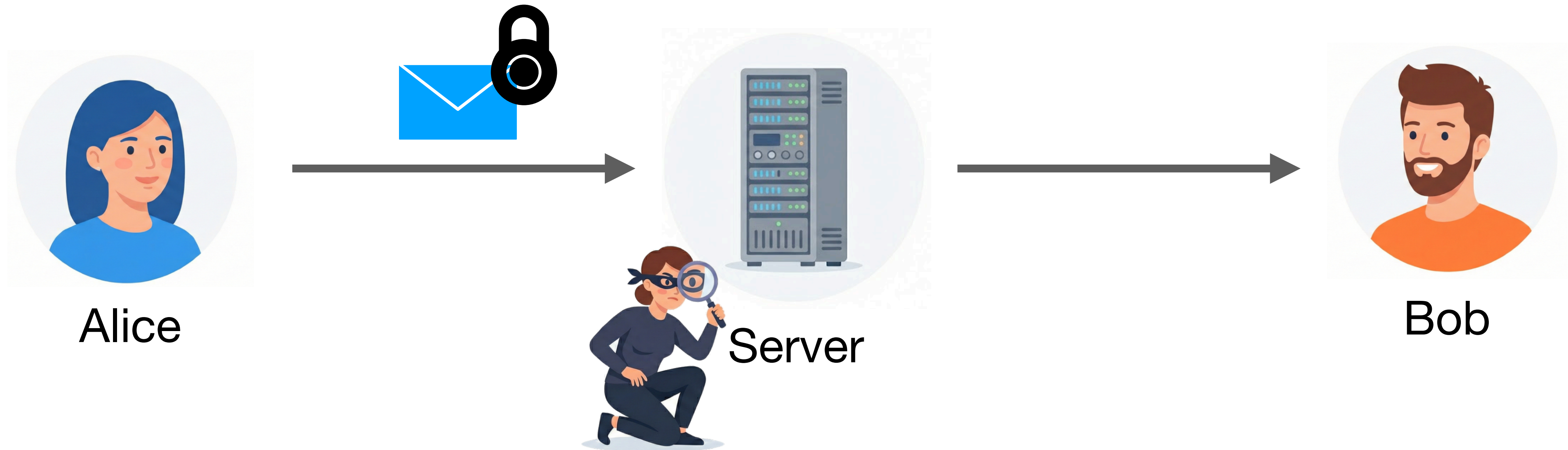
Server



Bob

Secure Messaging

Issue: Users are not always online.



- Server compromise
- Laws and warrants

The Signal protocol

Gold standard for **two-user** secure messaging.

It is used by billions of users.



Signal



WhatsApp



Facebook Messenger



Google Messages

The Signal protocol

Message secrecy

Minimum security. The server learns nothing about the messages.

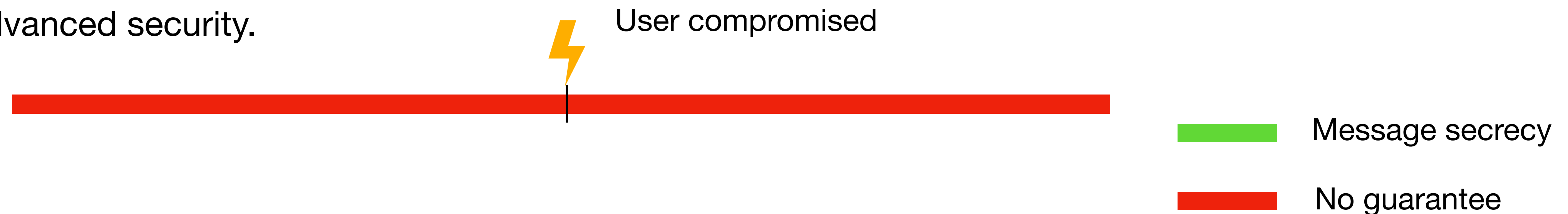
The Signal protocol

Message secrecy

Minimum security. The server learns nothing about the messages.

Advanced security properties. Some secrecy even when users get compromised.

Base case: no advanced security.



The Signal protocol

Message secrecy

Minimum security. The server learns nothing about the messages.

Advanced security properties. Some secrecy even when users get compromised.

Base case: no advanced security.

⚡ User compromised



■ Message secrecy

Signal: Post-Compromise Forward Security (PCFS).



■ No guarantee

The Signal protocol

Deniable Authentication

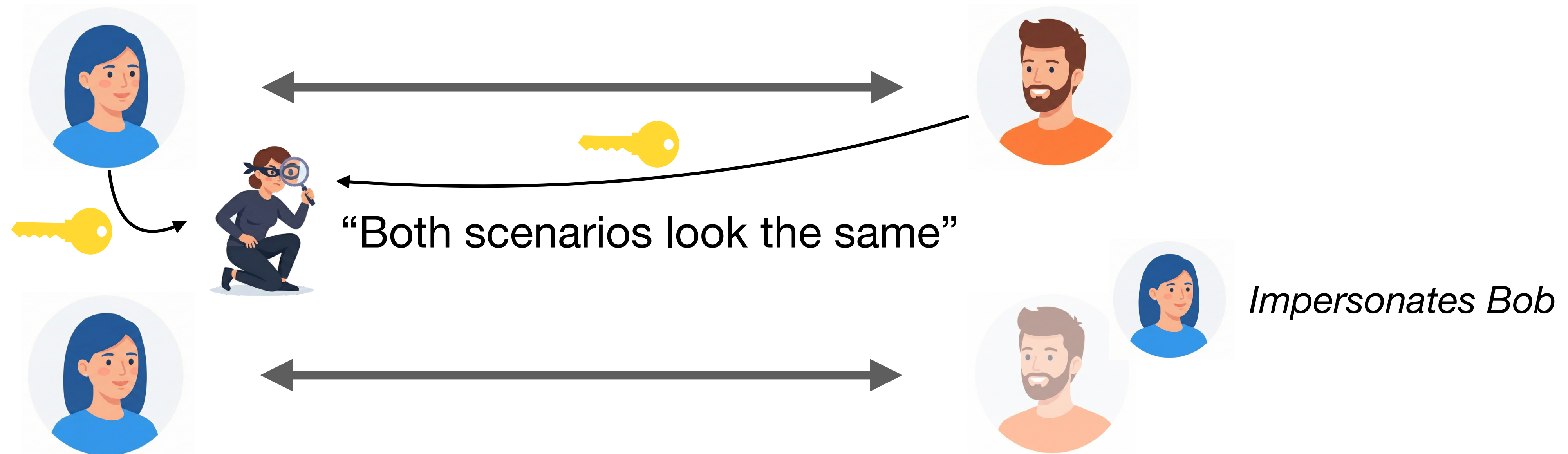
Deniable authentication. Users are sure they are talking to the right person, but they can deny participating in a conversation.

The Signal protocol

Deniable Authentication

Deniable authentication. Users are sure they are talking to the right person, but they can deny participating in a conversation.

Local deniability.

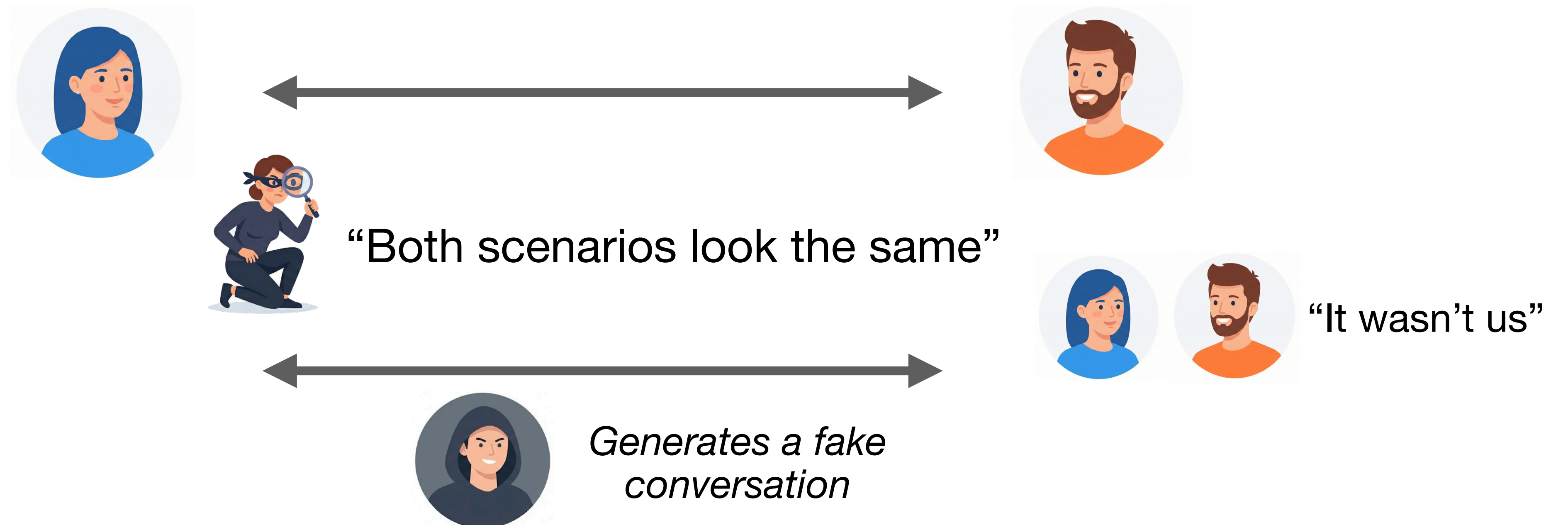


The Signal protocol

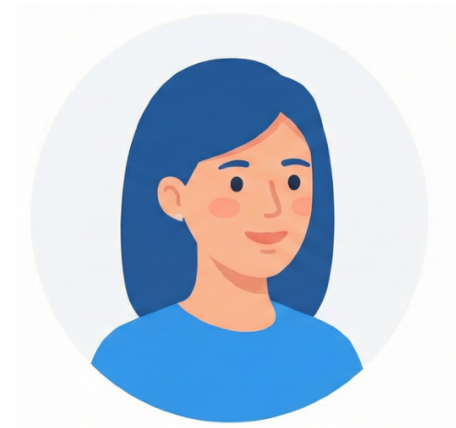
Deniable Authentication

Deniable authentication. Users are sure they are talking to the right person, but they can deny participating in a conversation.

Global deniability.



The Signal protocol (2016)



Long term keys



1

X3DH

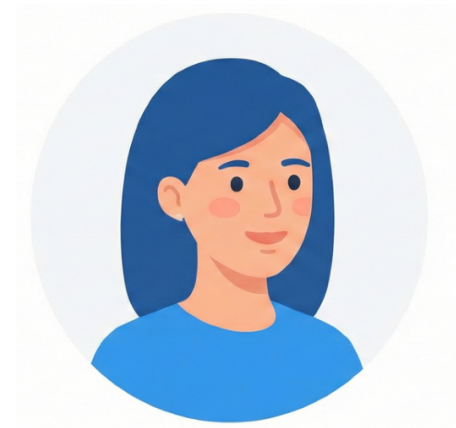
Establish a shared secret key.

2

Double Ratchet

Encrypted communication
with continuous key updates.

The Signal protocol (2016)



Long term keys



1

X3DH

Establish a shared secret key.

2

Double Ratchet

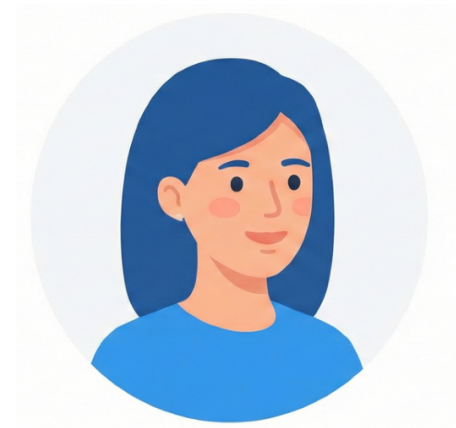
Encrypted communication
with continuous key updates.

provides

Deniable Authentication
+
Initial Forward Security

Post-Compromise Forward Security

The Signal protocol (2016)



Long term keys



1

X3DH

Establish a shared secret key.

2

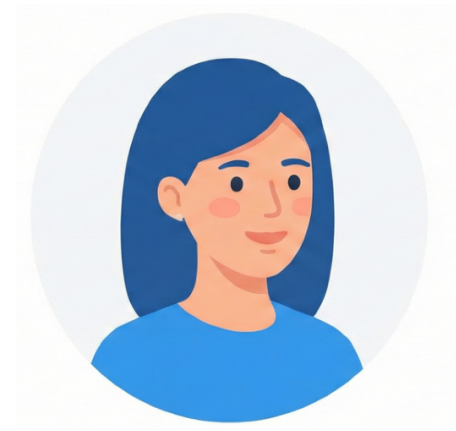
Double Ratchet

Encrypted communication
with continuous key updates.

... but it heavily relies on Diffie-Hellman.

How can we make it Post-Quantum secure?

The Signal protocol (2016)



Long term keys



1

X3DH

Establish a shared secret key.



2

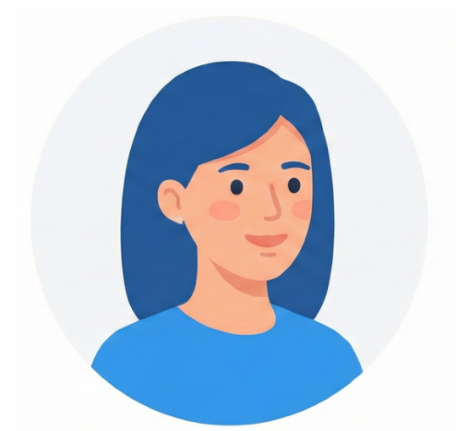
~~Triple~~ Double Ratchet (2025)

Encrypted communication
with continuous key updates.

Add “*ML-KEM ratchet*” on top of the previous symmetric and Diffie Hellman ones.

Split the ciphertexts over several messages to limit communication overhead.

The Signal protocol (2016)



Long term keys



1 ~~PQXDH~~ (2023)
X3DH

Establish a shared secret key.

2 ~~Triple~~ (2025)
Double Ratchet

Encrypted communication
with continuous key updates.

Add “*ML-KEM*” for PQ Initial Forward Secrecy.

But PQ deniable authentication?

Add “*ML-KEM ratchet*” on top of the previous symmetric and Diffie Hellman ones.

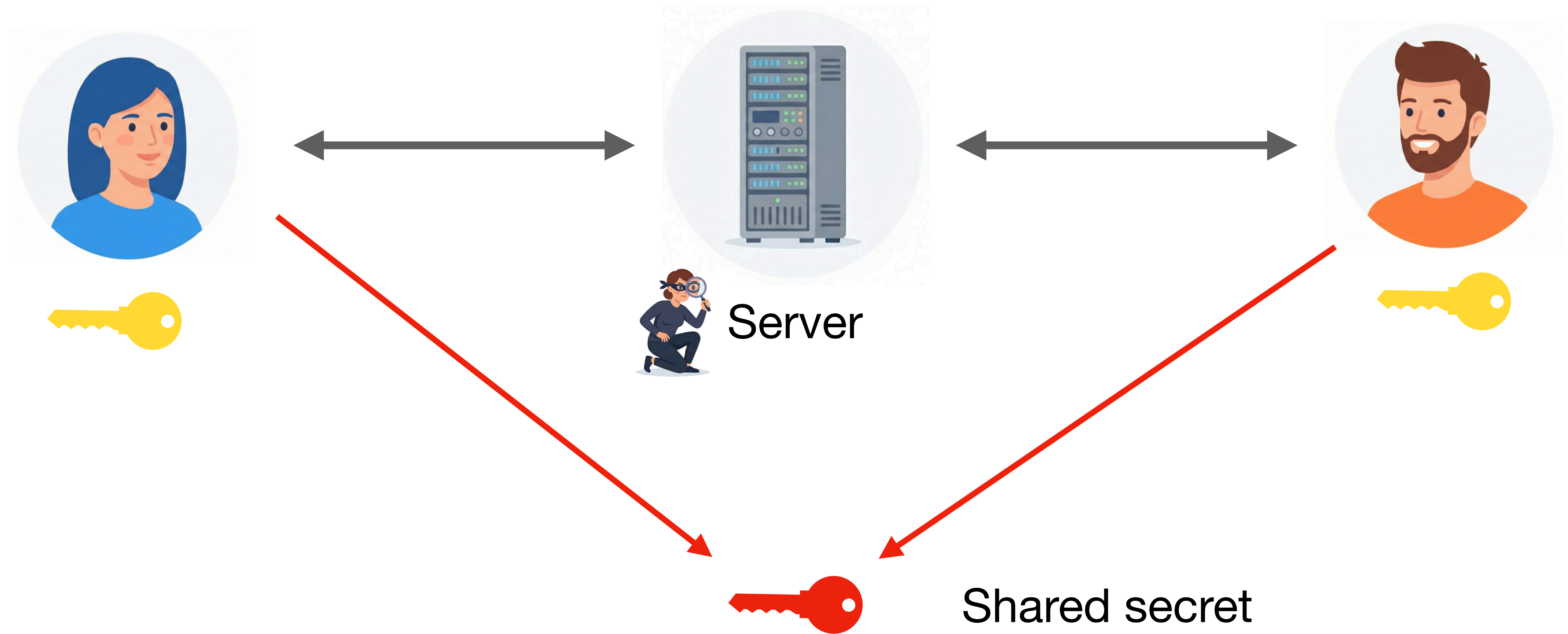
Split the ciphertexts over several messages to limit communication overhead.

Plan

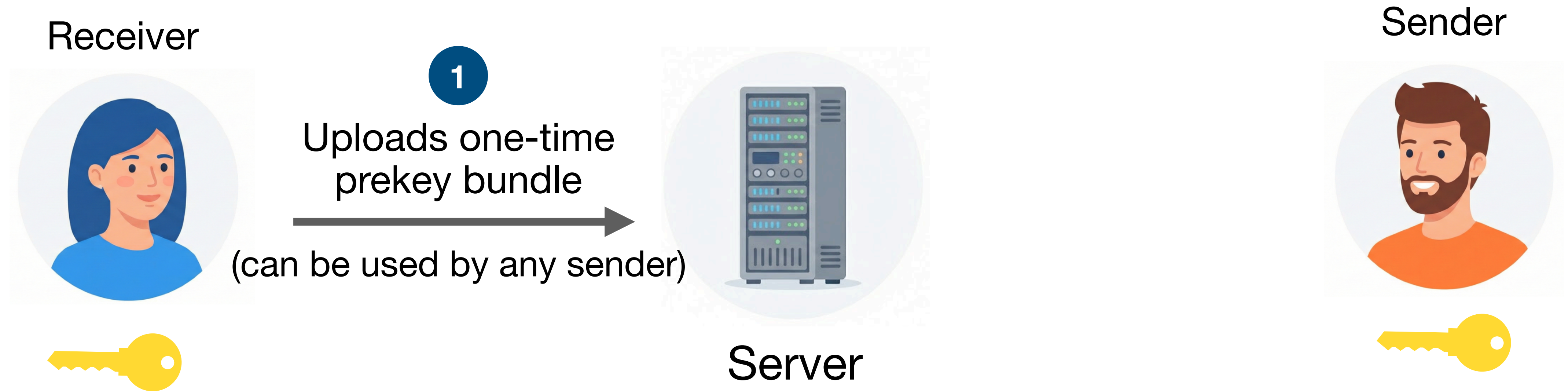
1. Signal's X3DH and PQXDH
2. RingXKEM: A fully post-quantum handshake
3. Modelling Signal's Handshake Protocols
 - a. Different levels of security
 - b. Deniability guarantees

X3DH and PQXDH

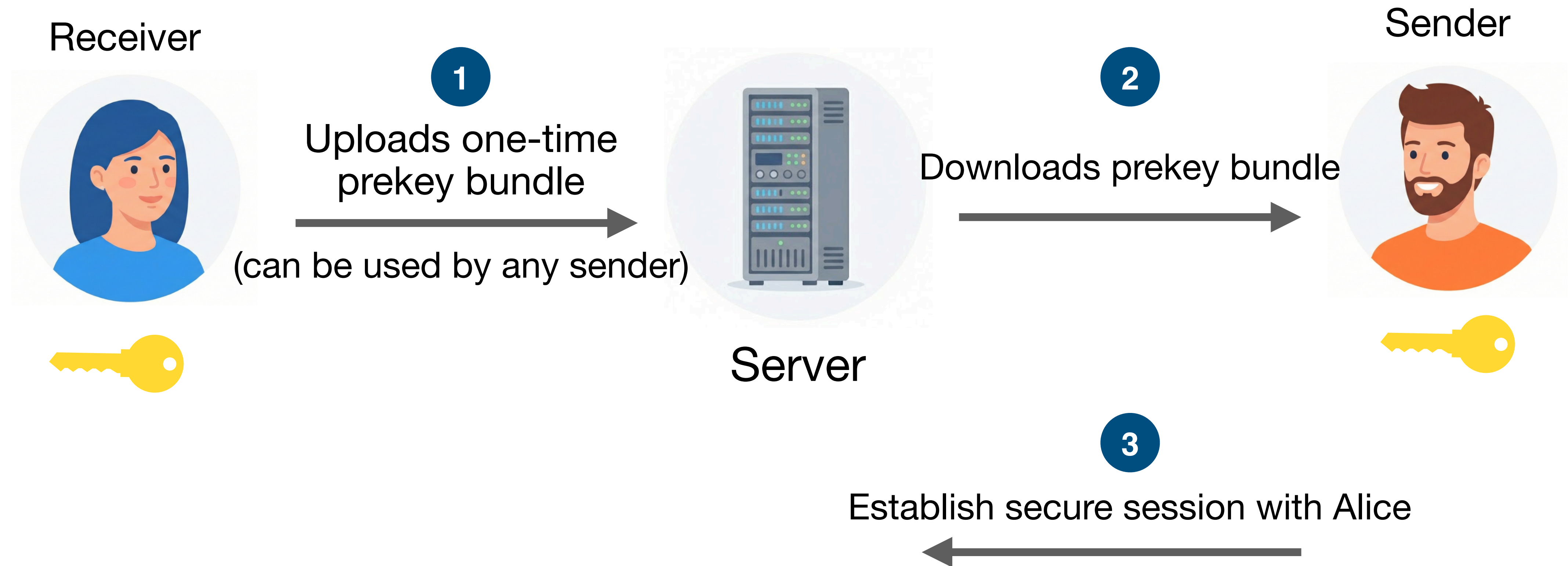
The X3DH protocol



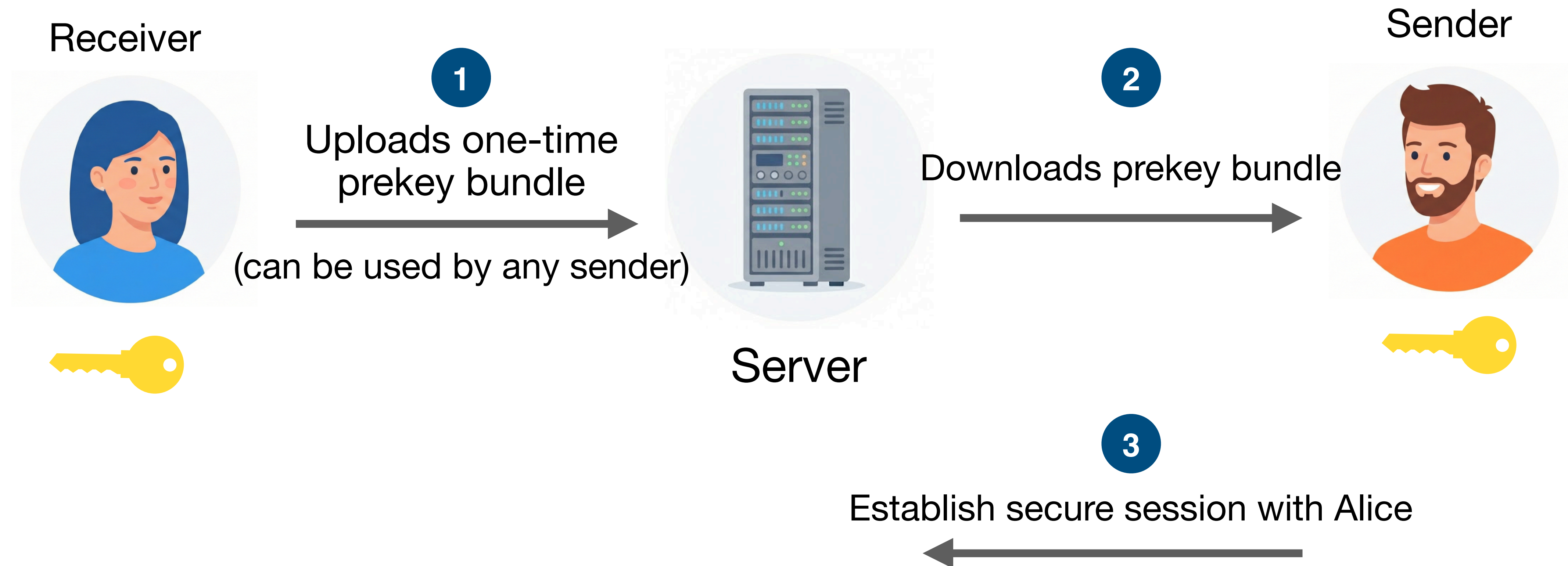
The X3DH protocol



The X3DH protocol



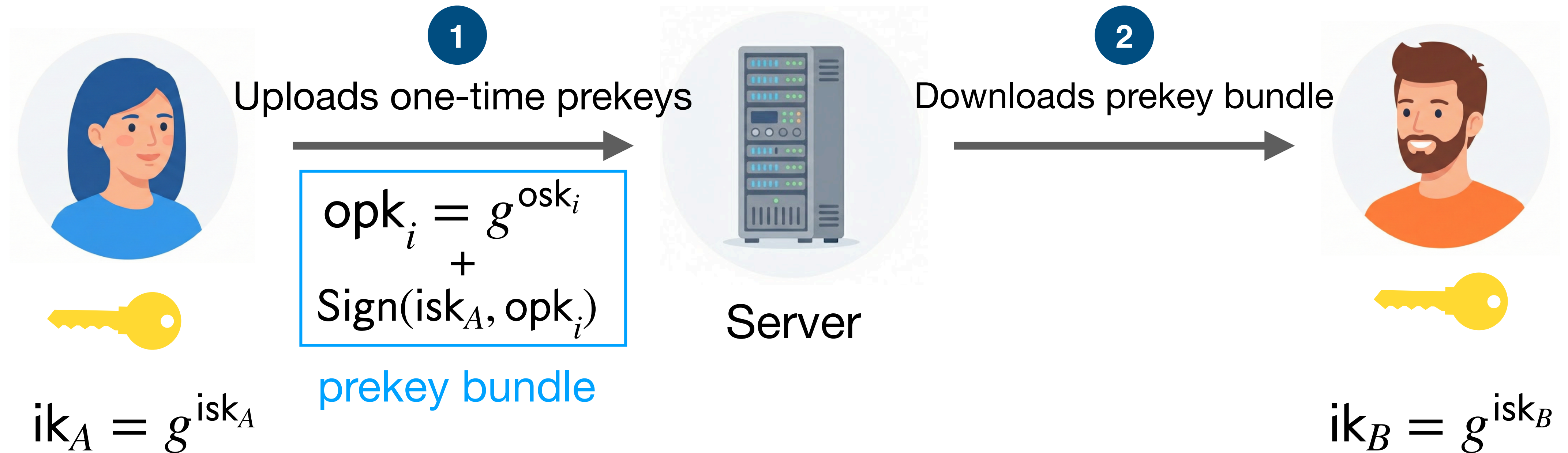
The X3DH protocol



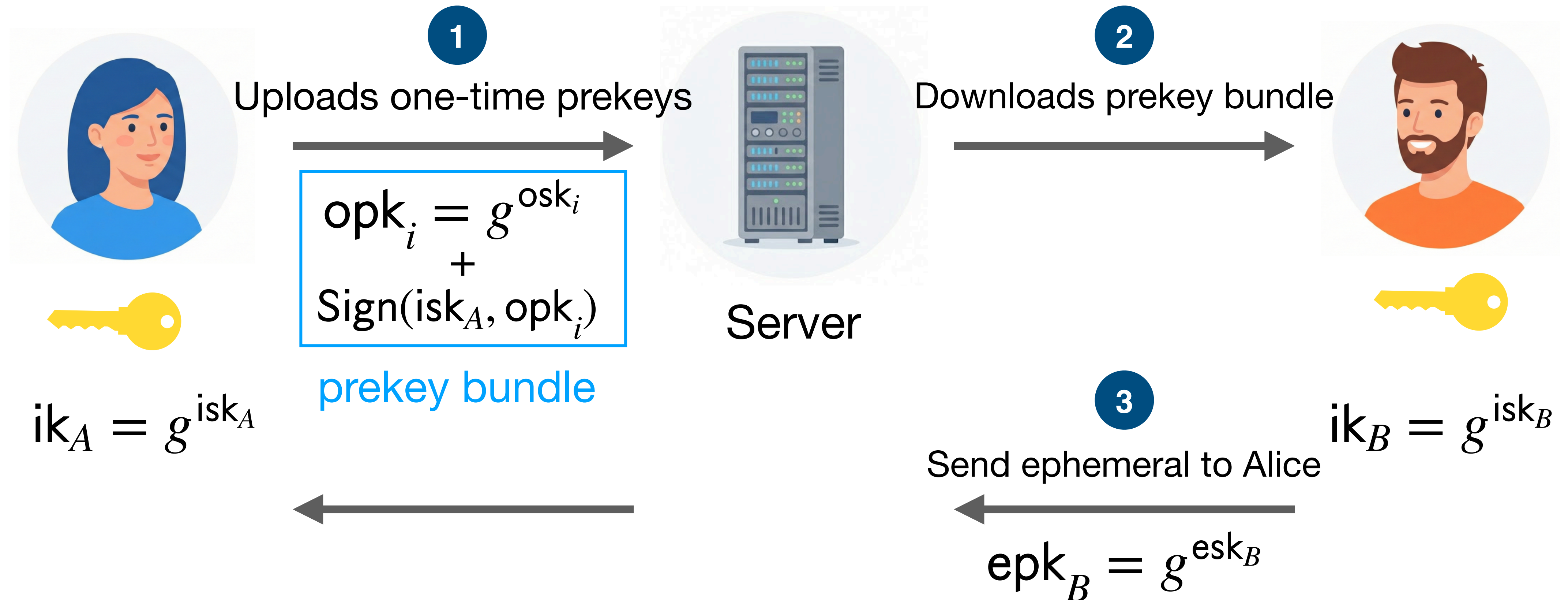
Remark: When Alice runs out of one-time prekey bundles, a special *last-resort prekey* is used.

Weaker forward security as it is kept around for a longer time.

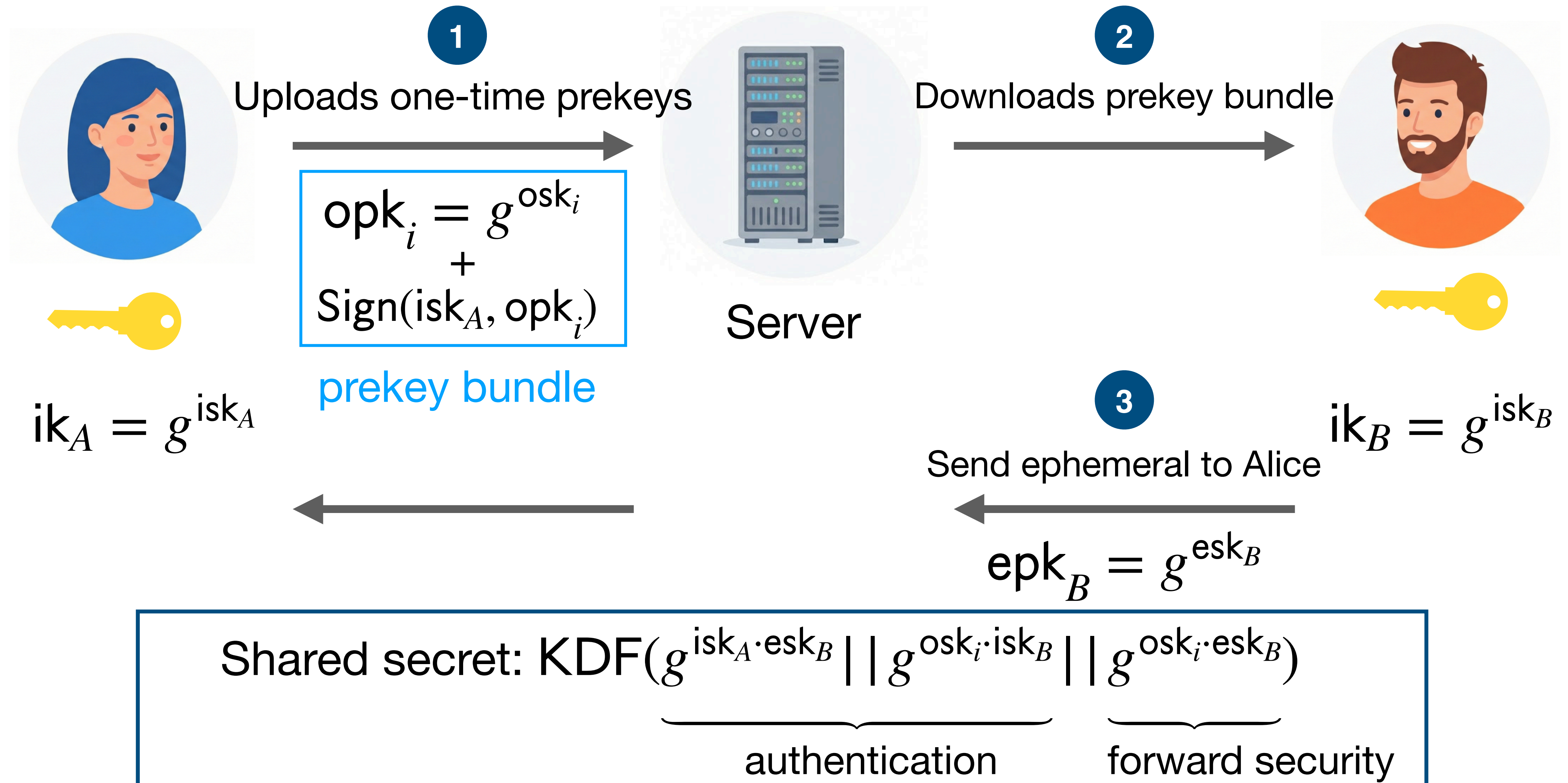
The X3DH protocol



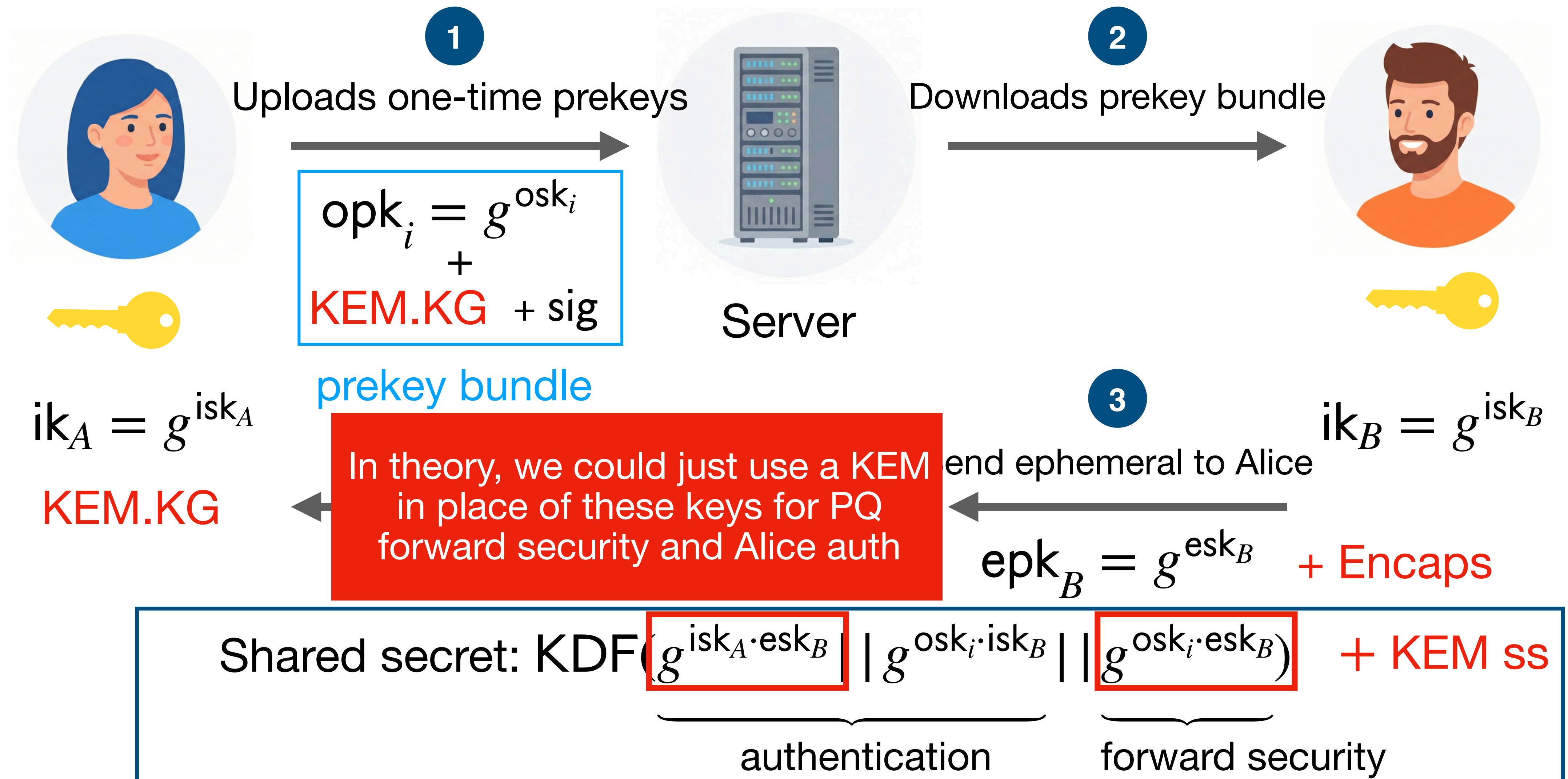
The X3DH protocol



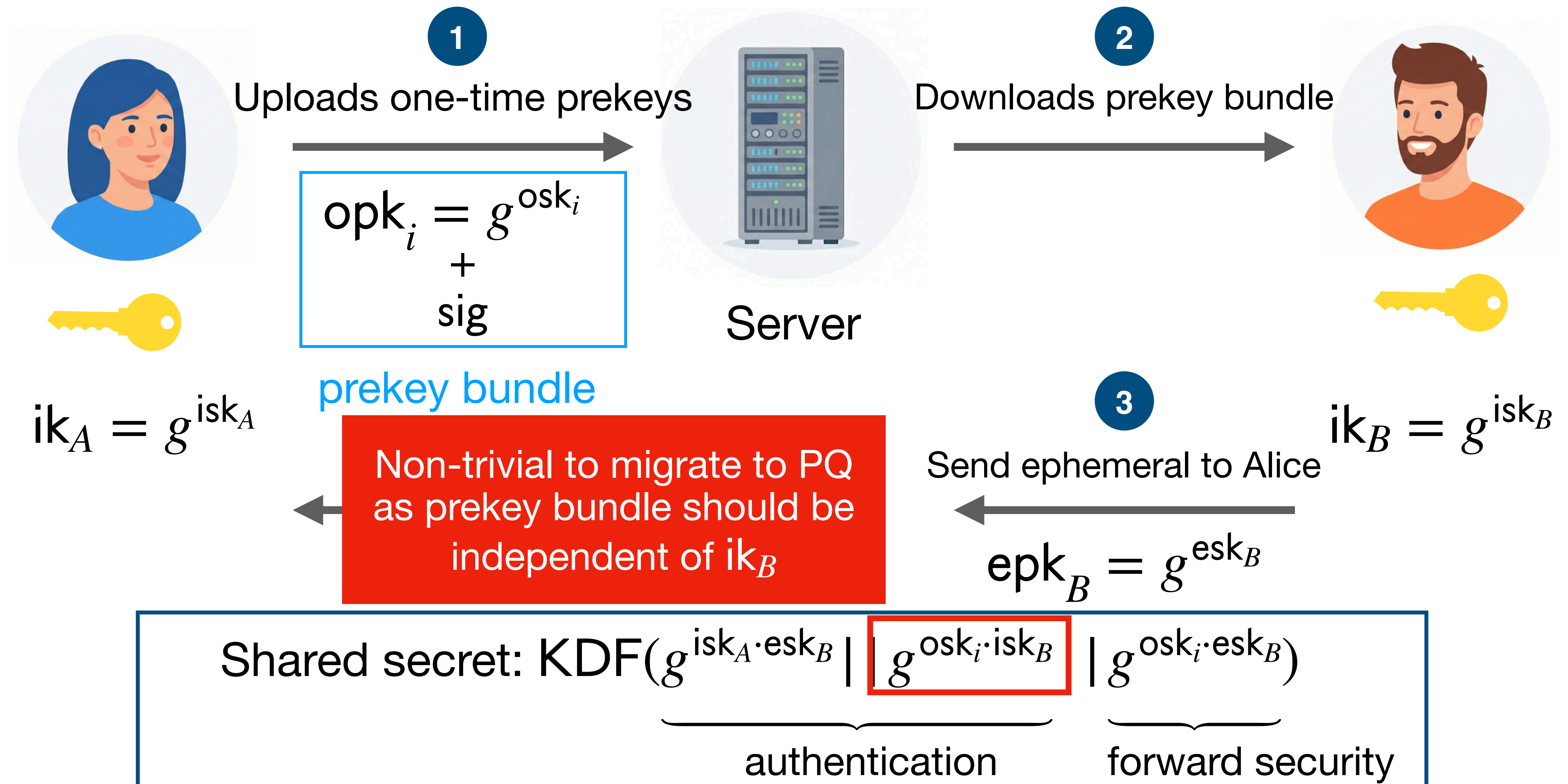
The X3DH protocol



The (PQ?)X3DH protocol

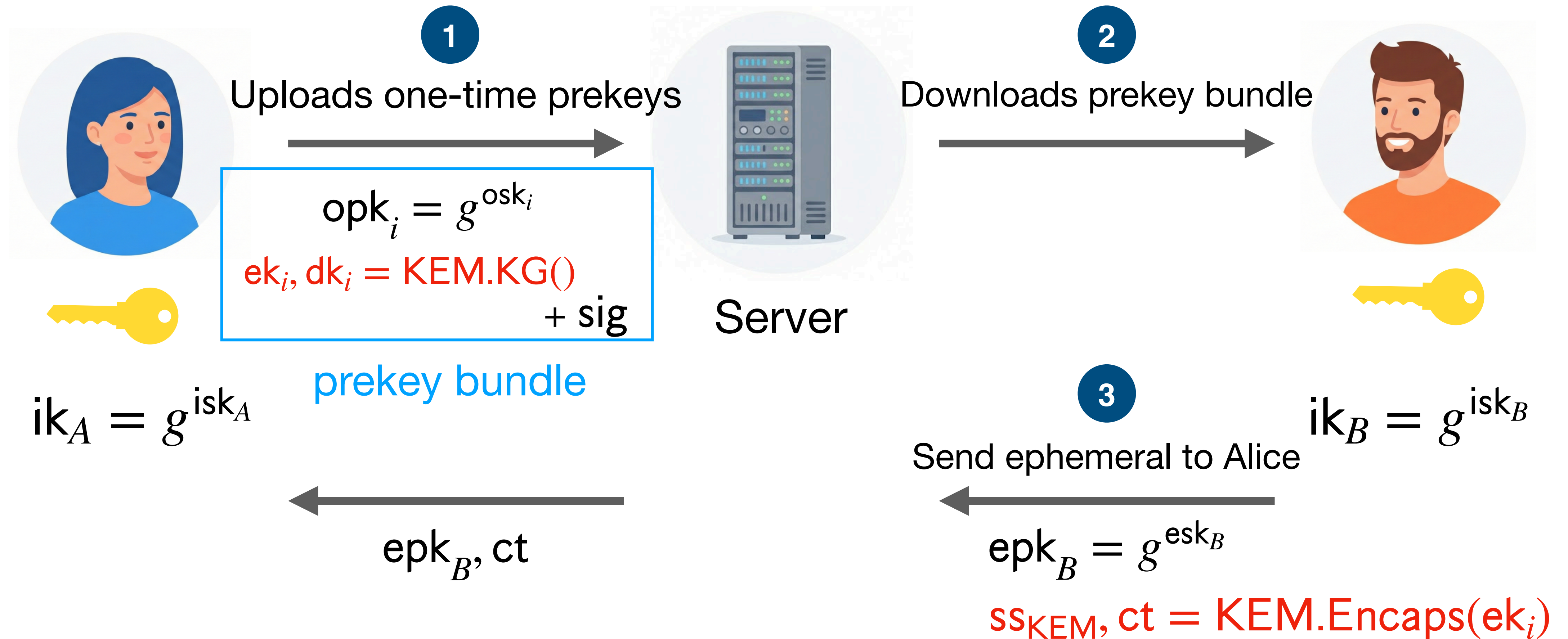


The (PQ?)X3DH protocol



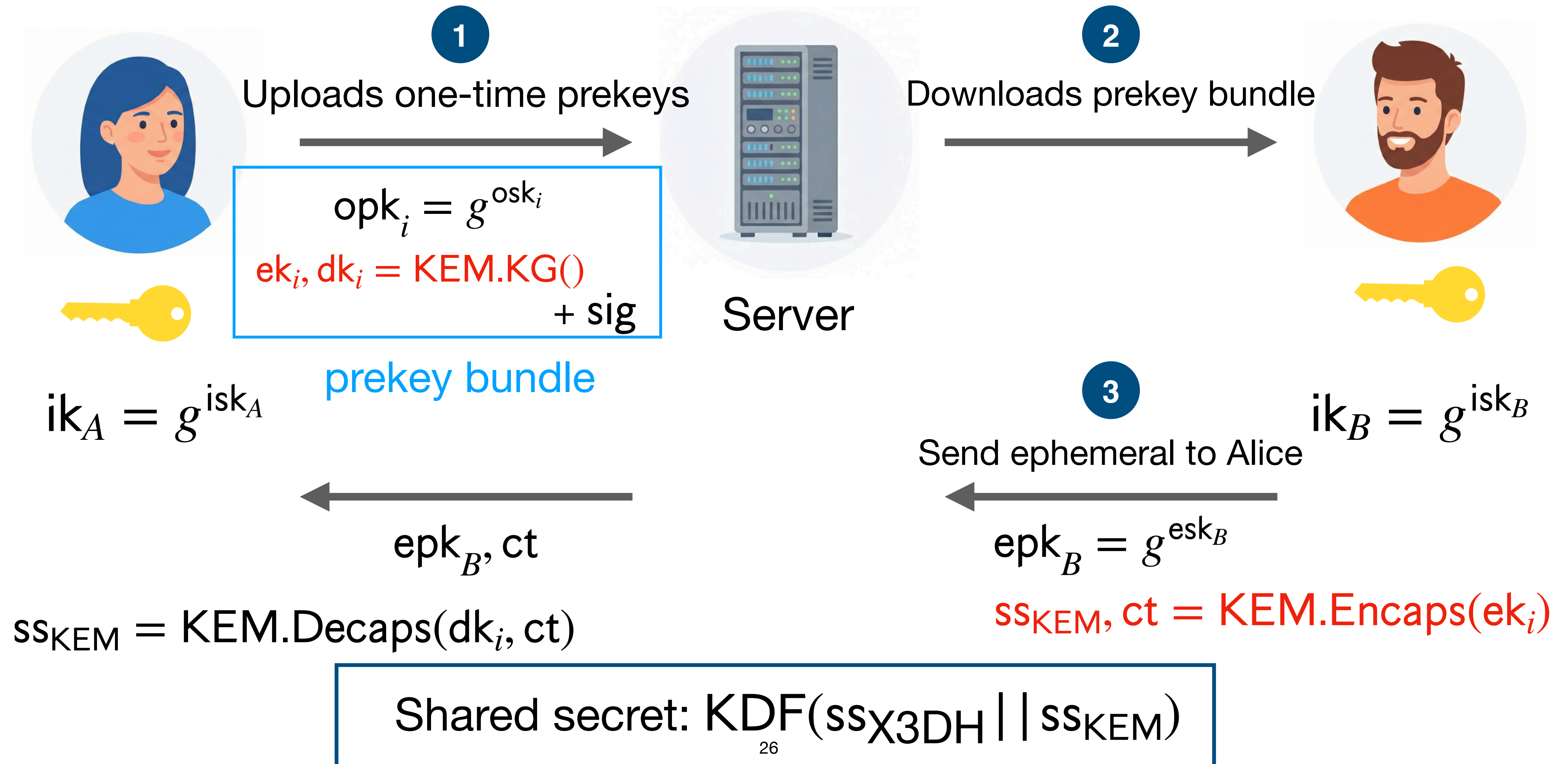
The PQX~~SDH~~ protocol

Only PQ forward security



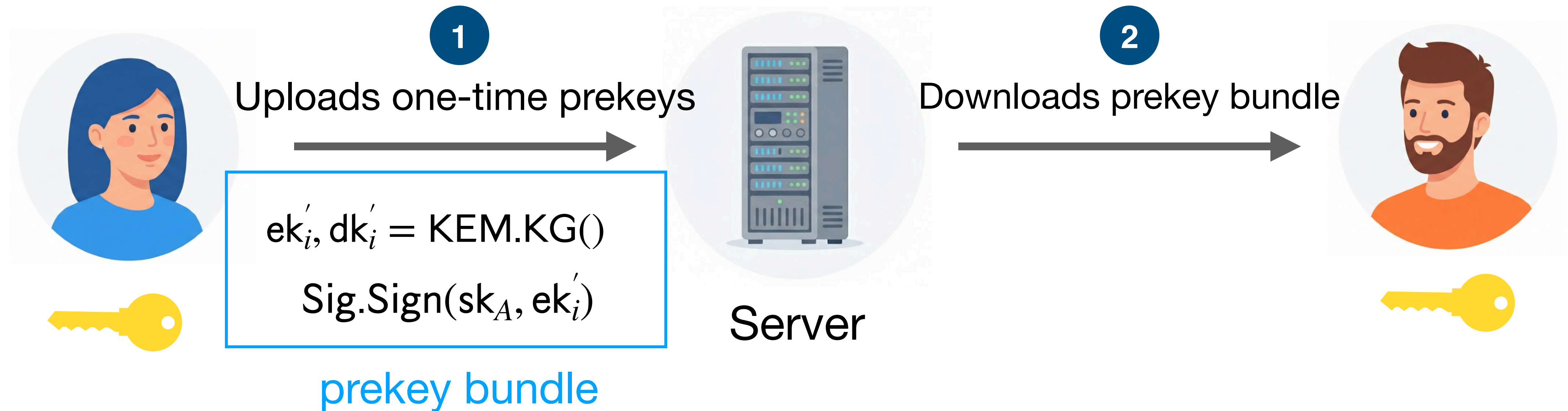
The PQX3DH protocol

Only PQ forward security



The Last Mile Towards PQ authentication?

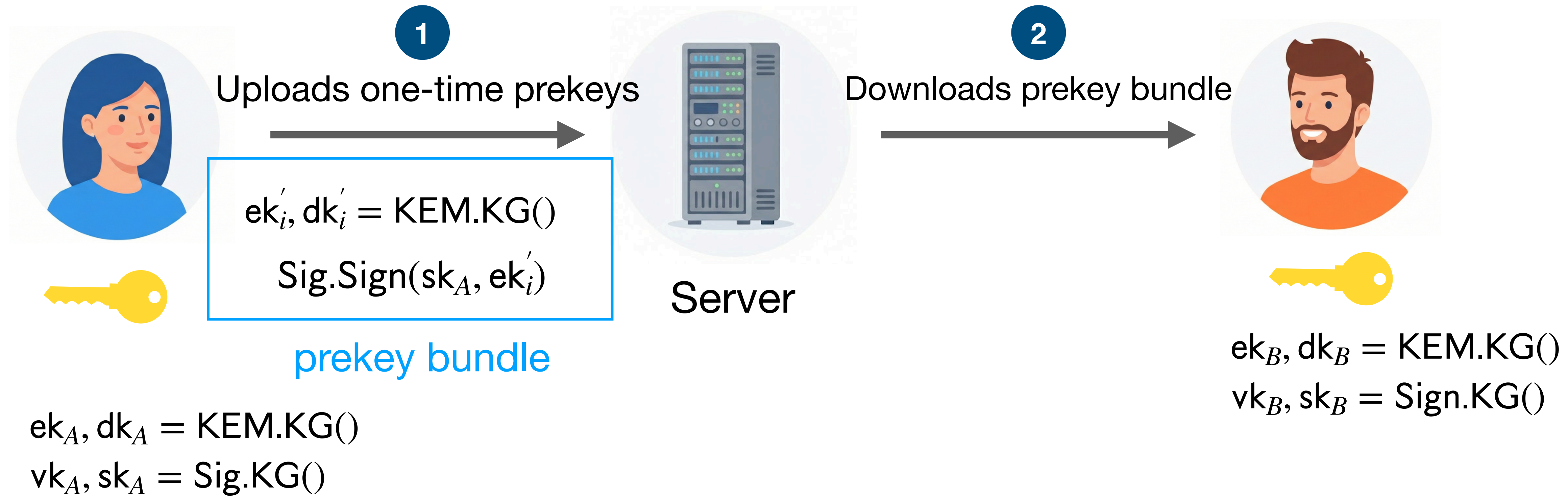
The Last Mile Towards PQ authentication?



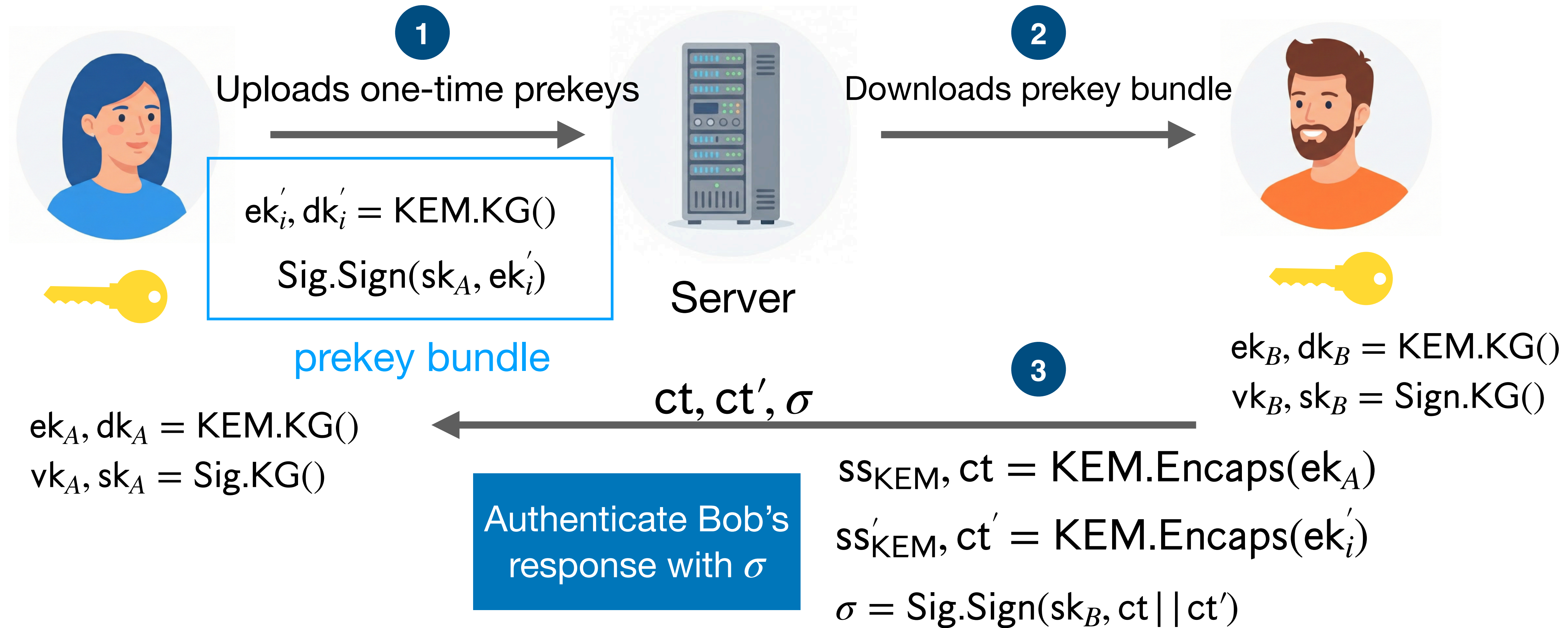
$ek_A, dk_A = \text{KEM.KG}()$
 $vk_A, sk_A = \text{Sig.KG}()$

Authenticate prekeys +
Protect against prekey
compromise

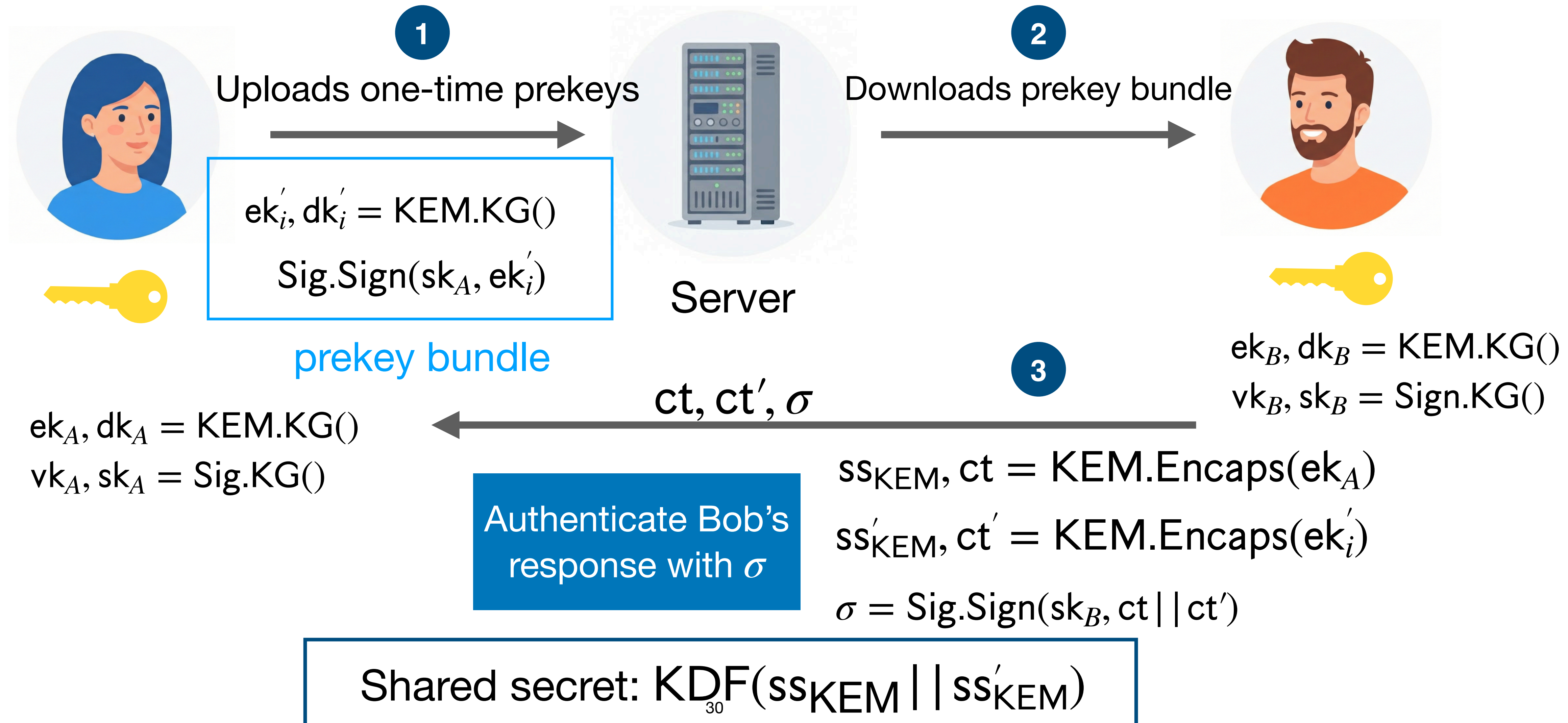
The Last Mile Towards PQ security?



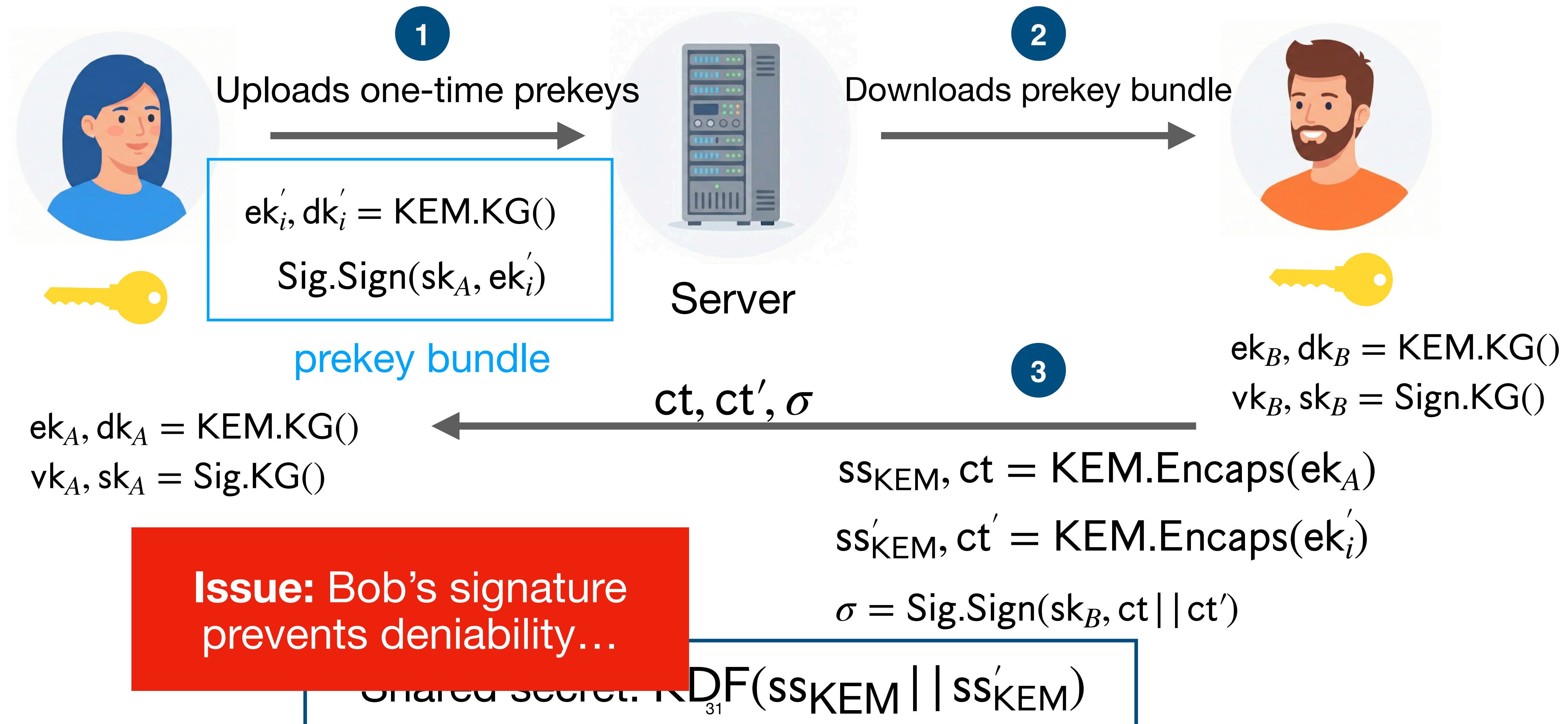
The Last Mile Towards PQ security?



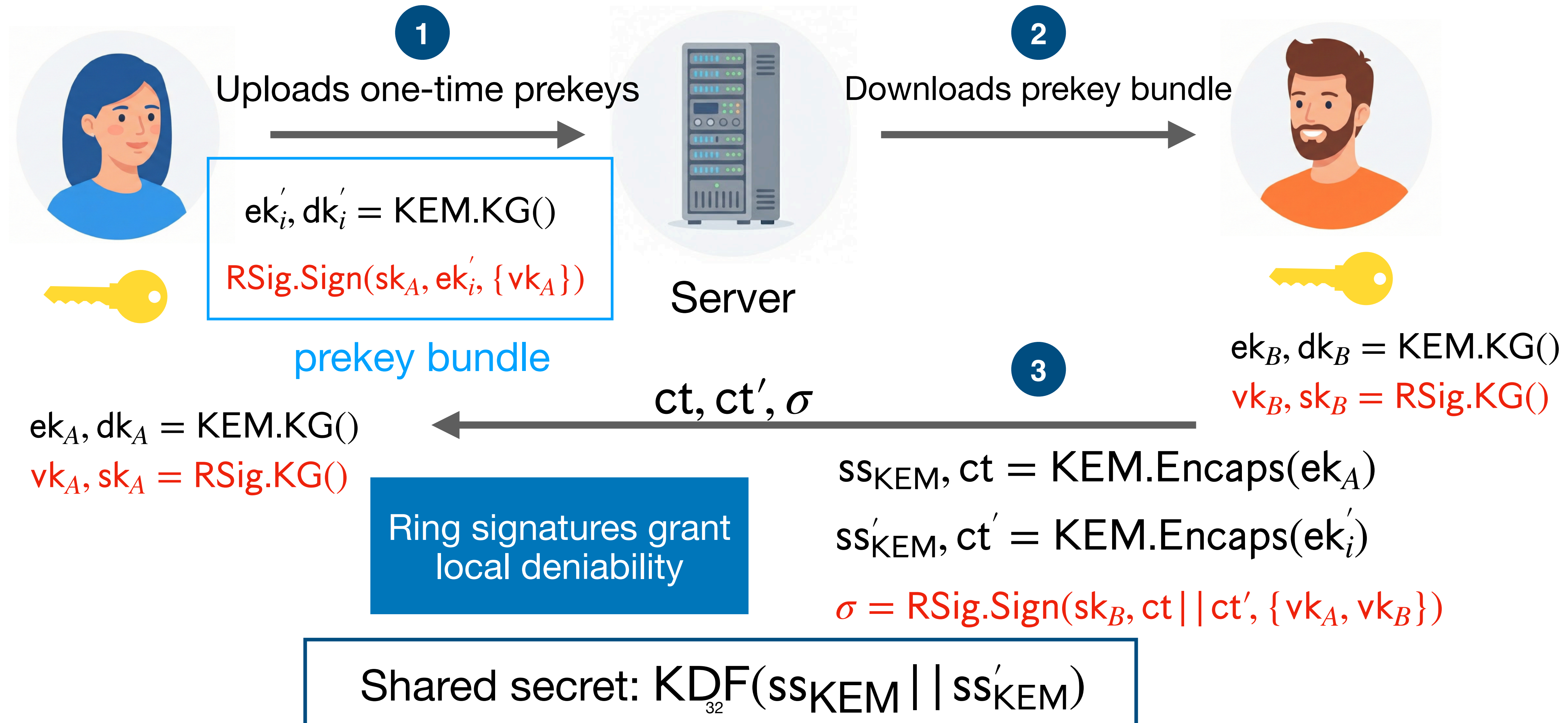
The Last Mile Towards PQ security?



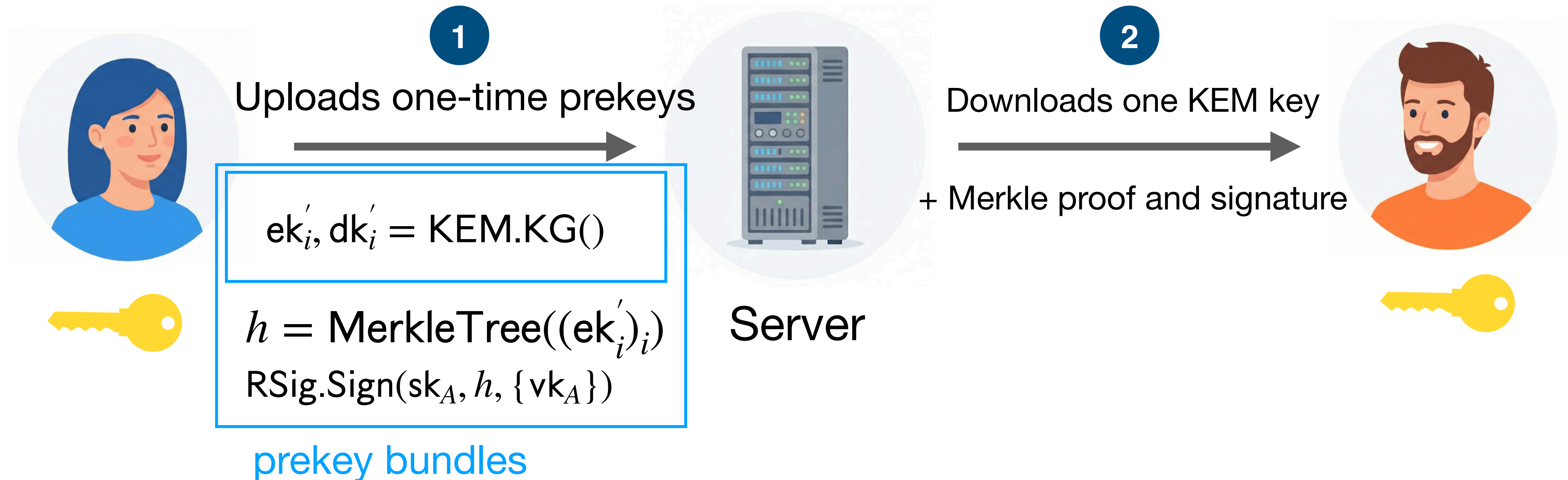
The Last Mile Towards PQ security?



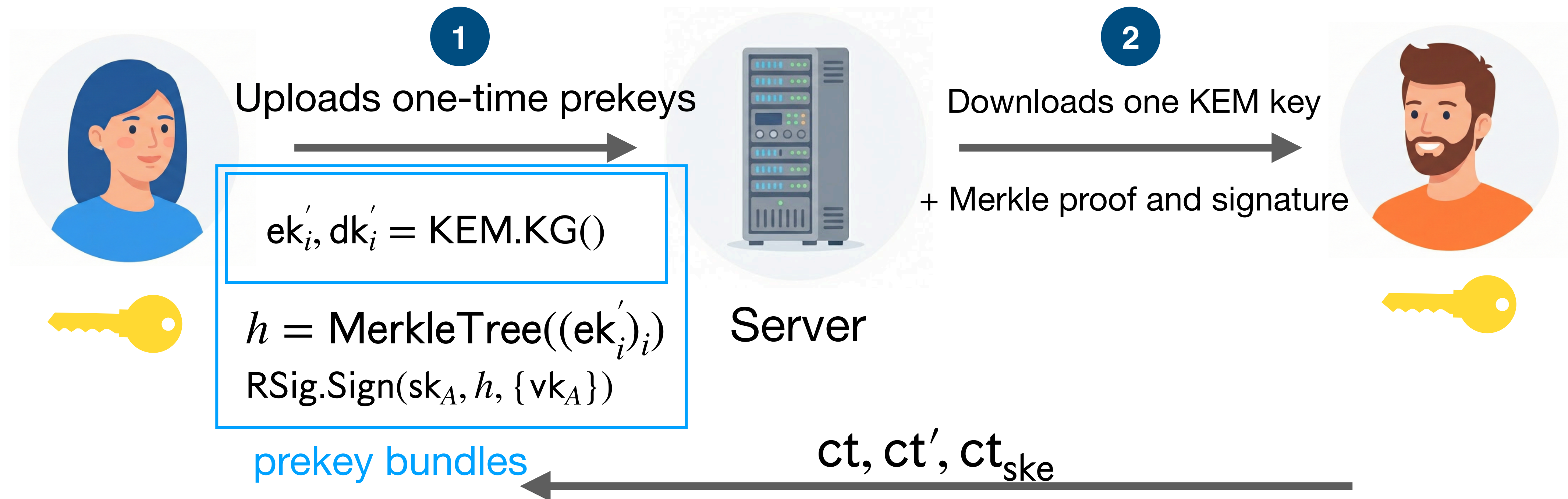
The Last Mile Towards PQ security?



RingXKEM: a few final modifications



RingXKEM: a few final modifications



Send a masked signature to add global deniability.

Alice and Bob can deny having a conversation against a third party.

$$ss_{\text{KEM}}, ct = \text{KEM.Encaps}(ek_A)$$

$$ss'_{\text{KEM}}, ct' = \text{KEM.Encaps}(ek'_i)$$

$$K || K_{ske} = \text{KDF}(ss_{\text{KEM}} || ss'_{\text{KEM}})$$

$$ct_{ske} = \text{SKE}(K_{ske}, \sigma)$$

Modeling the Signal Handshake

Modeling the Signal Handshake

Prior works defined ad-hoc models tailored to specific protocols and are insufficient for RingXKEM.

- Treat prekey bundles differently in each model
- Do not fully treat uploading of prekey bundles
- Don't capture all relevant adversaries
- Attained security **hard to compare**

Modeling the Signal Handshake

Prior works defined ad-hoc models tailored to specific protocols and are insufficient for RingXKEM.

- Treat prekey bundles differently in each model
- Do not fully treat uploading of prekey bundles
- Don't capture all relevant adversaries
- Attained security **hard to compare**

→ We introduce a unified model, with several levels of security and deniability

Bundled Authenticated Key Exchange (BAKE)

$\text{BAKE.IDKeyGen}(1^\lambda) \rightarrow (\text{ik}, \text{isk})$

Identity key generation algorithm

$\text{BAKE.PreKeyBundleGen}(\text{isk}_u) \rightarrow (\overrightarrow{\text{prek}}, \text{st}_u)$

Prekey bundle generation algorithm

$\text{BAKE.Send}(\text{isk}_s, \text{ik}_r, \text{prek}_{r,t}) \rightarrow (K, \rho)$

Sender (Bob) algorithm

$\text{BAKE.Receive}(\text{isk}_r, \text{st}_r, \text{ik}_s, t, \rho) \rightarrow (K', \text{st}_r)$

Receiver (Alice) algorithm

Bundled Authenticated Key Exchange (BAKE)

$\text{BAKE.IDKeyGen}(1^\lambda) \rightarrow (\text{ik}, \text{isk})$

Identity key generation algorithm

$\text{BAKE.PreKeyBundleGen}(\text{isk}_u) \rightarrow (\overrightarrow{\text{prek}}, \text{st}_u)$

Prekey bundle generation algorithm

$\text{BAKE.Send}(\text{isk}_s, \text{ik}_r, \text{prek}_{r,t}) \rightarrow (K, \rho)$

Sender (Bob) algorithm

$\text{BAKE.Receive}(\text{isk}_r, \text{st}_r, \text{ik}_s, t, \rho) \rightarrow (K', \text{st}_r)$

Receiver (Alice) algorithm

Single state for all uploaded prekey bundles

Bundled Authenticated Key Exchange (BAKE)

$\text{BAKE.IDKeyGen}(1^\lambda) \rightarrow (\text{ik}, \text{isk})$

Identity key generation algorithm

$\text{BAKE.PreKeyBundleGen}(\text{isk}_u) \rightarrow (\overrightarrow{\text{prek}}, \text{st}_u)$

Prekey bundle generation algorithm

$\text{BAKE.Send}(\text{isk}_s, \text{ik}_r, \text{prek}_{r,t}) \rightarrow (K, \rho)$

Sender (Bob) algorithm

$\text{BAKE.Receive}(\text{isk}_r, \text{st}_r, \text{ik}_s, t, \rho) \rightarrow (K', \text{st}_r)$

Receiver (Alice) algorithm

Refreshes prekey bundles and state

Bundled Authenticated Key Exchange (BAKE)

Batch of prekey bundles $\overrightarrow{\text{prek}}$ are composed of:

- **One-time** prekey bundles ($\text{prek}_1, \text{prek}_2, \dots, \text{prek}_L$)
 - Used **once** – prekey bundle and associated state **deleted after use**
- A single **last resort** prekey bundle $\text{prek}_\perp$
 - Used if one-time prekey bundles run out
 - **Re-used** until the next call to PreKeyBundleGen

Bundled Authenticated Key Exchange (BAKE)

Batch of prekey bundles $\overrightarrow{\text{prek}}$ are composed of:

- **One-time** prekey bundles ($\text{prek}_1, \text{prek}_2, \dots, \text{prek}_L$)
 - Used **once** – prekey bundle and associated state **deleted after use**
- A single **last resort** prekey bundle $\text{prek}_\perp$
 - Used if one-time prekey bundles run out
 - **Re-used** until the next call to PreKeyBundleGen

Consequence:

Handshakes with last resort key are vulnerable to state compromise even after the handshake completes and until refresh.

→ **weaker forward security**

Correctness and Security of BAKE

Correctness

Users honestly execute the BAKE protocol → derive identical session key.

Security (game based)

- Extends **AKE** to capture **(last-resort) prekey bundles**
- Model the security of a BAKE protocol via:
 - **Match soundness game:** Parties have a consistent view of who they are talking to.
 - **Key indistinguishability game:** Established session keys look random to the adversary, *even under maximum possible leakage*.

Correctness and Security of BAKE

Table 5: Security comparison of BAKE protocols.

Protocol	Adversary	Forward Secrecy	User-State Compromise Impersonation	Protocol-specific adversary restrictions
X3DH	Classical	Sender: weak Receiver: full	Receiver vulnerable	No quantum/HNDL adversaries.
PQXDH	HNDL	Sender: weak Receiver: full	Receiver vulnerable	KEM secret can not be revealed to HNDL adversary.
RingXKEM	Quantum	Full	Secure	No RingXKEM specific restrictions.

*weak forward secrecy**: X3DH and PQXDH do not actually fully sign prekey bundles

Deniability of BAKE

Setting:

- **Accuser** collects evidence relative to **accused user** which is provided to a **distinguisher**
- **Distinguisher** decides if evidence could have been simulated by the accuser

Modular framework:

- Differentiate who provides information to the distinguisher (accusers / accused)
- Accuser capabilities : **standard** (honest-but-curious) / **strong** (malicious)
- **Classical / quantum** accuser and distinguisher
- Scopes:
 - **Local** — accuser is sender or receiver
 - **Global** — both sender and receiver deny participation

Deniability of BAKE

“could have been simulated by the accuser”?

Previous works:

- Real & simulated evidence are **indistinguishable**.
 - **Conservative** (typically simulator outputs evidence with same probability as accused user)

Our approach:

- Accused user only needs to prove that evidence **could have been simulated**.
- Inspired by differential privacy and differential indistinguishability.
- Distributions close in terms of **hockey-stick divergence**.

→ “deniable” ring signatures from Falcon for RingXKEM

Deniable Ring Signatures

Deniability: Weakening anonymity

- **Anonymity:** signatures produced using two secret keys are indistinguishable.
- **New relaxation: Deniability**, Signature gives no hard evidence about which key was used to sign.

Compact Ring Signatures for Small Rings

- FalconRS, using components of standardized Falcon

Scheme	PK	2-RSig	Negligible anonymity
FalconRS (from Falcon-512)	897 B	1288 B	×
MayoRS ₁ (from MAYO ₁)	1168 B	650 B	×
MayoRS ₂ (from MAYO ₂)	5488 B	368 B	×
Gandalf [GJK24b]	896 B	1236 B	×
Raptor [LAZ19b]	900 B	2532 B	×
Calamari [BKP20]	64 B	3662 B	✓
DualRing-LB [Yue+21]	2496 B	3877 B	✓
Falafi [BKP20]	4096 B	30016 B	✓

Deniability of BAKE

Signal handshake protocol deniability properties													Legend								
Protocol:	X3DH		PQXDH		PQXDH		RingXKEM			SignXKEM			Last-resort prekey:								
	Classic $\mathcal{A}/D$		Classic $\mathcal{A}/D$		Classic $\mathcal{A}$ Quantum D		Classic or Quantum $\mathcal{A}/D$			Classic or Quantum $\mathcal{A}/D$			No	Yes							
Deniability Level	Leakage leak	disc	Leakage leak	disc	Leakage leak	disc	QROM	Leakage leak	disc	QROM	Leakage leak	disc	QROM	Icon	leak/disc	leak/disc					
local	●	●	●	●	●	●	✓	●	●	✓	●	●	✓	●	high	high					
global	●	●	●	●	●	●	✓	●	●	✓	●	●	✓	●	high	med					
strong-	local	●	●	●	●	●	?	●	●	?	●	●	?	●	med	med					
	global	●	●	●	●	●	?	●	●	?	●	●	?	●	med	low					
	local	●	●	●	●	●	?	●	●	?	●	●	?	●	low	low					
	global	●	●	●	●	●	?	●	●	?	●	●	?	●	low	low					
Security [HKW25]													Open problem								
Classical													Harvest-Now Decrypt-Later			Fully post-quantum			Accusers $\mathcal{A}$ restricted to being senders, no deniability otherwise.		
																			Proof using GGM.		

Example: RingXKEM is local deniable with leakage leak = high and disclosure disc = high even if a last-resort prekey bundle was used. SignXKEM is local deniable with leak = high and disc = med, but restricted to leak = med and disc = low using a last resort prekey bundle.

Remark: For strong deniability, we always set disc = high, since we have no control over the information a malicious accuser may reveal.

Conclusion

Future Work

Collaboration with Felix Günther¹, Vadim Lyubashevsky¹, and Rolfe Schmidt²

- Designing fully PQ handshake protocol for Signal
- Space/bandwidth optimizations for Falcon-based signatures and ring signatures
- Considering the use of RingXKEM for the next fully PQ Signal protocol

¹. IBM Research Europe, Zurich

². Signal Messenger

Take aways

- Signal's Handshake is not yet fully PQ secure
 - **RingXKEM**, based on ring signatures, is a promising proposal
 - Stronger security guarantees than X3DH / PQXDH
 - At least as deniable as PQXDH (for setting of concern to Signal)
 - Optimized sizes with Merkle Tree trick
- Bundled AKE protocols (BAKE) formalism
 - Formally model **prekey bundles** and their states
 - **Unified framework** for Signal handshake protocols
 - Framework for analyzing deniability
 - ◆ Novel metric → relaxed, pragmatic guarantees for deniability

Full versions



“Bundled Authenticated Key Exchange: A Concrete Treatment of (Post-Quantum) Signal’s Handshake Protocol.”

By Hashimoto, Katsumata, and Wiggers.

USENIX Security 2025
eprint.iacr.org/2025/040



“Comprehensive Deniability Analysis of Signal Handshake Protocols: X3DH, PQXDH to Fully Post-Quantum with Deniable Ring Signatures.”

By Katsumata, Niot, Tucker, Wiggers.

USENIX Security 2025
eprint.iacr.org/2025/1090